Book 5 — Clearing Security Topology and Resilience Configuration

Title	**Book 5: Clearing Security Topology and Resilience Configuration**
Author	**Mr Denis Bouzon**
ORCID	**0009-0007-8894-8902**
Version / date	**2.1; 17 October 2026**
Landing page	**www.osnias-clearing.com/security**
Licence	**© Osnias Clearing — Creative Commons Attribution 4.0 International**
DOI URL	

Prior Osnias documentation

Book 1	Osnias ID	https://www.osnias-clearing.com/osniasid/
Book 2	Architecture	https://www.osnias-clearing.com/architecture/
Book 3	Rules	https://www.osnias-clearing.com/rules/
Book 4	Cycles / Calendar	https://www.osnias-clearing.com/cycles/
Book 5	Security	https://www.osnias-clearing.com/security/
Book 6	Onboarding	https://www.osnias-clearing.com/onboarding/
Book 7	O-POP	https://www.osnias-clearing.com/pop/

Abstract

This document presents the Osnias Clearing end-user security architecture throughout the identity lifecycle: onboarding, authorization in two independent domains, secure fund release, cryptographic renewal and off-boarding. It also describes the administrative roles of the node manager and the Osnias manager, their dedicated keys, and the controls governing netting and node escrow limits. Its objective is to reduce the risk that compromise of a single operational ECDSA key could lead to diversion of escrowed funds.

The architecture uses existing chains as they are. It separates the operational EVM signing address, an independent Sei authorization domain, and a cold EVM release destination generated from a separate seed and pre-committed in the smart contract. The release destination is intended to remain non-signing during its designated receiving phase and to serve as a pre-committed beneficiary rather than an operational authorization key, so compromise of the operational signer does not, by itself, confer control over the destination of released funds.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

A future attack against exposed ECDSA public keys is treated as a prospective cryptographic risk, not as an asserted present operational threat. The design philosophy is long-horizon security engineering: use mechanisms available on current chains to reduce a plausible risk class extending across a long operational and cryptographic horizon, without claiming that ECDSA itself has become post-quantum secure. Document level: internal technical assessment and audit-readiness review. Controls are classified by evidence status; this document is not an independent audit, formal verification, penetration-test report or production-security certification.

Keywords

Osnias-ID; onboarding; off-boarding; ECDSA; secp256k1; EVM escrow; quantum risk; cold receiving address; dual-domain authorization; defence in depth; cryptographic hygiene; Shor-based attack.

Table des matières

1 Statut de l'évaluation et niveau documentaire....3
2 Périmètre, méthode et référentiels de l'évaluation....3
2.1 Référentiels méthodologiques....4
3 Matrice d'évaluation des contrôles....4
4 Objet, principes de sécurité et périmètre....5
4.1 Perspective de sécurité à long terme....5
4.2 Propriétés recherchées....5
4.3 Propriétés non revendiquées....6
5 Cycle de vie de la sécurité de l'utilisateur....6
6 Architecture de l'entrée sécurisée....6
6.1 Domaine A — Signataire EVM opérationnel....6
6.2 Domaine B — Autorisation Sei indépendante....6
6.3 Domaine C — Adresse froide de réception indépendante....6
6.4 Indépendance des graines et risque de cascade BIP-32....7
6.5 Condition composite de libération....8
6.6 Règle du bénéficiaire prédéfini....8
6.7 Ensemble minimal des données liées à l'autorisation....8
6.8 Autorisation à usage unique et protection contre le rejeu....8
6.9 Cycle de vie du portefeuille de réception....8
7 Modèle de menace à long terme : compromission d'une clé et risque lié à Shor....8
7.1 Scénario prospectif lié à Shor....8
7.2 Objectif de l'attaquant....9
7.3 Pourquoi la clé récupérée reste insuffisante....9
7.4 Surface d'attaque résiduelle....9
8 Osnias-ID, intégrité des registres et protection contre le rejeu....9
8.1 Cohérence des registres et risque TOCTOU....9
8.2 Séparation du plan de contrôle....9
9 WW=00 : mode de sécurité du séquestre autonome....9
10 Hygiène cryptographique, renouvellement de l'identité et sortie....10
10.1 Renouvellement complet....10
10.2 Sortie et révocation définitive....11
11 Exigences de renforcement institutionnel....11
12 Limites et travaux ouverts....12
13 Feuille de route de l'implémentation et de la validation de sécurité....12
14 Conclusion....13
15 Bibliographie....13

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

Assessment Status and Document Level

This document is an internal technical assessment and audit-readiness review of the intended Osnias Clearing end-user security design. It examines the architecture, trust boundaries, control objectives, open risks and evidence required for subsequent implementation validation. It is not an independent audit, formal verification, penetration test, asset-custody audit, legal opinion, certification or authorization for production deployment.

Assessment item	Current status
Document level	Internal technical assessment and security audit-readiness review
Review basis	Osnias Clearing End-User Security Architecture — Version 4.3
Reviewer	Denis Bouzon / Osnias Clearing — internal assessment
Implementation evidence	Pending for the controls identified in this document
Adversarial testnet campaign	Pending
Independent third-party audit	Not performed
Production-security certification	Not claimed
Overall status	Design assessed; implementation evidence, adversarial testing and independent review pending

Evidence-status vocabulary used in this assessment: DESIGN REQUIREMENT — intended security property; SPECIFIED — control semantics described; IMPLEMENTATION PENDING — code-level evidence not yet available; TESTING PENDING — adversarial evidence not yet available; OPEN — material design or implementation decision remains unresolved; INDEPENDENTLY REVIEWED — reserved for controls later examined by an identified independent reviewer.

Audit Scope, Methodology and Reference Frameworks

Scope. The review covers the operational EVM signer, independent Sei authorization, pre-registered cold beneficiary, composite release predicate, replay protection, Osnias-ID and registry consistency, cross-chain verification assumptions, identity renewal and off-boarding, administrative powers, the dedicated keys of the node manager and the Osnias manager, netting adjustments and per-node escrow limits, participant key custody and planned validation.

Assessment exclusions. The review does not attest deployed bytecode, production infrastructure, wallet vendors, participant custody environments, source-chain consensus correctness, legal or regulatory compliance, or the effectiveness of controls that have not yet been implemented and evidenced. Although source-chain consensus correctness is outside the scope of this assessment, the cross-chain release design remains dependent on an explicitly documented finality and source-state-authentication assumption.

Methodology. Controls are assessed through architecture review, trust-boundary analysis, compromise-scenario analysis, invariant identification, lifecycle review, administrative-power analysis, cross-chain failure analysis, residual-risk identification and definition of implementation evidence and adversarial tests required before production qualification.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

Reference frameworks used as methodological guidance

- ISO 19011:2026 — Guidelines for auditing management systems: audit principles, audit-program structure and evidence-based/risk-based audit practice.
- ISO/IEC 27001:2022 — Information security management systems: risk-governance and information-security management context.
- ISO/IEC 27002:2022 — Information security controls: control-oriented security guidance, including access control and cryptography-related practices.
- ISO/IEC 27005:2022 — Guidance on managing information security risks: structured risk identification, assessment and treatment.
- ISO/IEC 27034-1:2011 — Application security: integration of application security concepts and processes into the application lifecycle.
- NIST SP 800-218, SSDF v1.1 — Secure Software Development Framework: secure development practices, vulnerability reduction and evidence across the software lifecycle.

Reference-framework notice. These standards and frameworks are cited as methodological and security-design references only. Their citation does not imply ISO certification, conformity assessment, NIST endorsement, independent validation or a claim that Osnias Clearing has been audited against the complete requirements of any cited standard.

Control Assessment Matrix

The matrix below distinguishes design-level requirements from implementation evidence. Severity identifies the consequence of an absent or bypassed control; it is not a statement that a vulnerability has already been observed in deployed code. The Required next action column records the evidence or implementation work needed to advance each control toward verification.

ID	Control / finding	Severity	Current evidence status	Required action
SEC-001	The operational signer must not freely select or replace the release beneficiary.	Critical	DESIGN REQUIREMENT	Implement and test contract-level beneficiary immutability or controlled changes; verify that arbitrary destinations are rejected.
SEC-002	Release authorization must be single-use and bound to the nonce, proof and pre-registered beneficiary.	High	SPECIFIED	Consume nonces and proofs; test replay and substitution of contract, chain, amount or beneficiary.
SEC-003	Canonical Sei-state authentication, finality and reorganizations, verifier quorum and rotation require implementation evidence.	High	OPEN	Define these mechanisms; test failures and stale state.
SEC-004	No single upgrade, registry, verifier or emergency authority may bypass the composite condition or unilaterally change the beneficiary.	Critical	DESIGN REQUIREMENT	Define separation of roles and threshold controls; test administrative and emergency-path abuse.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

SEC-005	Seeds A, B and C require independent roots and common-mode failure isolation; keys remain in participant custody.	High	SPECIFIED / IMPLEMENTATION PENDING	Document generation and custody; demonstrate independent roots and test onboarding misconfigurations.
SEC-006	Identity migration and successor binding require a state machine and adversarial tests.	High	IMPLEMENTATION PENDING	Implement states, bindings, migration conditions and terminal revocation; test migration attacks.
SEC-007	Static analysis, testnet attack scenarios, remediation and retesting remain necessary before independent review.	High	TESTING PENDING	Run Slither and the adversarial campaign; remediate, retest and publish the validation report.
SEC-008	The node manager's dedicated key may act only on its node, within the authorized window and in accordance with finalized net positions.	Critical	DESIGN REQUIREMENT / IMPLEMENTATION PENDING	Test operations outside the assigned node or window, unjustified amounts, unregistered destinations and duplicate execution; verify treatment of debit and credit balances.
SEC-009	The Osnias manager's key administers node numbers and parameters without disposing of node assets; contracts must enforce escrow limits.	High	DESIGN REQUIREMENT / IMPLEMENTATION PENDING	Specify limit units, scope, changes and reductions; test limit breaches and abuse of administrative privileges.
SEC-010	Manager seeds must be independent of one another and of Domains A, B and C; rotation and revocation must preserve role restrictions.	High	DESIGN REQUIREMENT / TESTING PENDING	Document generation, custody and recovery; test assignment, revocation, rotation and compromise of each management key.
SEC-011	Participants may adjust escrow only on days 2–4; all withdrawals must go to the registered dedicated address; escrow is locked at Thursday close.	Critical	DESIGN REQUIREMENT / IMPLEMENTATION AND TESTING PENDING	Specify the UTC closing boundary; test additions and withdrawals at window boundaries, non-releasable amounts, destination substitution, limit breaches and continued availability of authorized settlement operations.

Severity interpretation: Critical — absence could enable direct fund diversion or collapse of the intended authorization separation; High — material security control or trust-boundary weakness; Medium — weakness requiring correction before production; Low — hardening recommendation; Informational — observation without demonstrated direct security impact.

Administrative target invariant. No single upgrade, registry, verifier or emergency authority should be able to alter the release predicate, rewrite the registered release beneficiary or disable the independent second-domain condition unilaterally. The exact threshold, timelock and separation-of-duty mechanisms remain implementation evidence to be supplied before this control can be independently verified.

Purpose, Security Philosophy and Scope

Osnias Clearing treats end-user fund security as a lifecycle property rather than as a single-signature problem. The protocol separates operational signing, independent authorization, fund destination, registry state and identity lifecycle controls. The architecture is designed to be deployable on current EVM and Sei infrastructure while reducing the consequences of a future compromise of exposed classical signing keys.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

Design principle: reduce future risks using the chains available today.

Long-horizon security perspective

Shor's algorithm establishes a theoretical path to solving the elliptic-curve discrete logarithm problem on a sufficiently capable quantum computer. This paper does not assert that such capability is presently available against secp256k1 accounts in operational blockchain conditions. The quantum scenario is therefore treated as prospective. The engineering question is narrower: if a future attacker recovers an exposed operational signing key, should that key alone be sufficient to divert escrowed funds?

Osnias answers this question architecturally. Rather than changing ECDSA, it changes the conditions under which funds can be released and where they can be sent. This is a defence-in-depth strategy, not a claim of post-quantum completeness.

What is claimed

- Compromise of the operational EVM signing key should remain insufficient, by itself, to satisfy the complete release predicate.
- A second independently generated authorization domain on Sei can add an independent cryptographic precondition.
- A pre-committed cold EVM release destination can separate signing authority from fund destination authority.
- **The architecture can be implemented using existing EVM contracts, EOA addresses, registry state, nonces and authenticated cross-chain state.**

What is not claimed

- No complete quantum resistance, formal reduction or quantified post-quantum security level is claimed.
- The cold release address does not make ECDSA post-quantum; it reduces the usefulness of compromise of the operational signer for fund diversion.
- **Verifier, registry governance, source-chain consensus and upgrade authority remain explicit trust boundaries.**

End-User Security Lifecycle

The end-user security lifecycle is organized as onboarding, active operation, secure fund release, optional identity renewal and off-boarding. Osnias provides the mechanisms and state transitions; the participant retains control over its own security policy, including whether and when to renew its cryptographic identity.

- Onboarding establishes the Osnias-ID and binds the operational EVM signer, the independent Sei authorization domain and the cold release destination.
- Active operation uses the operational signer for routine EVM interactions while the second domain and verifier constrain release authority.
- Fund release is directed only to the pre-committed release beneficiary, not to an arbitrary destination supplied at release time.
- Renewal and off-boarding create a new identity when desired, migrate or settle remaining positions, and end with irreversible revocation of the prior identity.

Secure Onboarding Architecture

Onboarding creates the security identity used by the protocol. Osnias-ID is the binding layer; it is not itself a cryptographic key. Security depends on separating the technical roles associated with that identifier.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

Domain A — Operational EVM signer

Domain A contains the participant's operational EVM signing key and address. Recommended end-user profile: the operational EVM key is generated and retained on a hardware wallet, so routine EVM signatures can be produced while private-key material remains isolated from the general-purpose host. This key is operational and potentially exposed through normal signing activity; it must not be the sole authority capable of determining the final destination of released escrow funds.

Domain B — Independent Sei authorization

Domain B is generated from an independent seed root and participates in the canonical Sei authorization or state-transition path. A participant may use an operational Sei-compatible wallet (for example, MetaMask where supported by the selected Sei environment) for routine Sei-side authorization. No shared seed, derivation root or recovery material should exist between Domain A and Domain B. Network separation alone is insufficient if the underlying seed material is common.

Domain C — Independent cold release destination

Onboarding also records a dedicated EVM release beneficiary generated from a third, independent seed. Recommended end-user profile: Seed C is retained offline as a cold release wallet and is normally unused for routine signing. Its address is registered as the release beneficiary. During its designated receiving phase it need not sign any transaction, so its public key is not revealed through an outgoing ECDSA signature merely by receiving funds.

The release beneficiary is pre-committed before the release event. The operational signer must not be able to substitute an arbitrary destination at release time. A change of release beneficiary should require a separately governed renewal or re-onboarding procedure rather than a unilateral action by the operational signer.

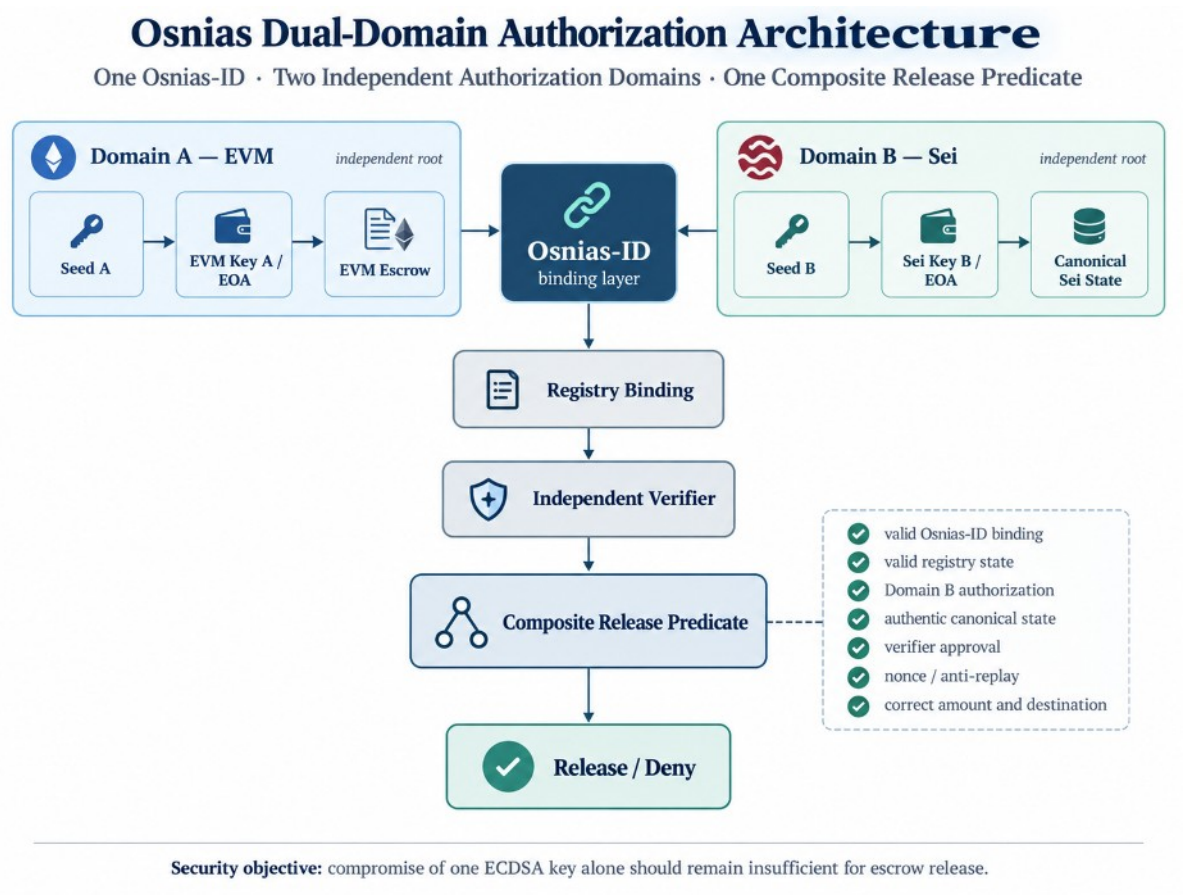


Figure 1 — Dual-domain authorization architecture

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

Seed independence and BIP-32 cascade risk

Seed A, Seed B and Seed C should be independently generated; shared roots undermine the intended separation. Multiple addresses derived from one common seed do not constitute independent security domains. Independent seed roots should also avoid a common compromised generation environment where practicable.

Participant custody responsibility. Seeds A, B and C, their private keys, recovery phrases, hardware devices and backup material remain under the end-user participant's custody and operational responsibility. Osnias Clearing does not hold, escrow, back up, recover or control participant private keys or seed phrases. The participant remains responsible for its key-generation environment, storage, recovery procedures, access controls and custody policy.

Common-mode isolation. Distinct seeds created on the same compromised device, session, recovery environment or shared administrative control plane do not provide complete fault-domain isolation. Institutional deployments should evidence separation through controlled key ceremonies, segregated HSM/custody domains or equivalent approved procedures where appropriate.

Domain B signing risk. Independent authorization does not protect against malicious co-signing or blind signing. The target control is to bind Sei authorization to human-readable intent, Osnias-ID, beneficiary, asset, amount, nonce and expiry, allowing the participant to verify the operation before approval. 7. Composite Authorization and Secure Fund Release

The release function is designed around a composite predicate. A valid signature by the operational EVM signer is necessary only where the relevant protocol action requires it; it is not sufficient to redirect escrow funds.

Composite release predicate

Audit objective — composite release condition. The design requires a valid Osnias-ID binding, an acceptable registry state, authenticated second-domain authorization or canonical source-chain state, verifier approval, freshness and replay protection, and an exact match to the pre-committed release beneficiary. Contract-level enforcement remains subject to implementation evidence and testing.

If the composite condition is satisfied, funds go to the registered cold beneficiary, never to an address supplied at the last minute by the operational signer.

Pre-committed beneficiary rule

Design requirement — pre-registered beneficiary. The beneficiary must be registered during onboarding or through a process providing equivalent protection. The normal release path must not allow the operational signer to provide an arbitrary destination. Evidence of contract-level enforcement is required before this control can be considered verified.

Minimum binding tuple

A production authorization should bind, at minimum: protocol version and domain separator; Osnias-ID; source and destination chain identifiers; verifying escrow contract; specific asset identifier; ISO 4217 currency code where applicable; cycle or mode; amount; unique nonce; canonical source-state reference; release authorization identifier; beneficiary commitment; timestamp; and expiry or freshness condition.

Single-use authorization and replay resistance

The proof must be single-use. The escrow should record consumption of the authorization nonce or proof identifier and reject replay, cross-contract substitution, cross-chain substitution, amount changes and beneficiary changes.

Release wallet lifecycle

The cold release address is non-signing during its designated receiving phase and is used as a pre-committed beneficiary, not as an operational authorization key. If the participant later moves those funds, the address enters an active signing phase. As an optional hygiene practice, the participant may then designate a newly

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

generated cold release address for future releases. This remains a participant security-policy decision rather than a mandatory protocol interval.

Long-Horizon Threat Model: Single-Key and Shor Risk

Security goal SG-1 — Single-key insufficiency: recovery of one participant ECDSA private key, including the operational EVM signing key, must not by itself satisfy the complete authorization predicate for release of escrowed funds to an attacker-controlled destination. This is a target security property of the design, not an implementation finding or independently verified result.

Prospective Shor scenario

Shor's algorithm and its elliptic-curve adaptations make ECDLP polynomial-time on an ideal sufficiently capable quantum computer. The protocol does not change that fact. Instead, it assumes that a future attacker may obtain the operational private key corresponding to a public key exposed through normal signing activity and asks what the attacker can do next.

Attacker objective

The economically meaningful attacker objective is not merely to impersonate the signer. It is to cause the escrow to transfer legitimate participant funds to an attacker-controlled address. Release 4.3 separates these capabilities.

Compromise of 0xSIGNER does not give control of 0xRELEASE.

Why the recovered signer remains insufficient

Recovery of the operational EVM key does not, under the single-key-compromise model, provide a known shortcut to the independently generated Sei key, does not create authentic canonical Sei state, does not satisfy the independent verifier, and does not reveal or control the private key of the independently generated cold release address. If the release beneficiary is immutable or strongly pre-committed, the attacker cannot simply substitute 0xATTACKER as the destination.

Residual attack surface

The attacker must therefore compromise or bypass additional trust boundaries: the second authorization domain, registry integrity, canonical-state verification, verifier control, upgrade governance or the release-beneficiary binding. These remain explicit residual risks.

Osnias-ID, Registry Integrity and Replay Protection

Osnias-ID binds the participant's security domains and lifecycle state. It does not create cryptographic strength by itself. Registry integrity is therefore a security boundary: bindings must be authentic, version-consistent and fail closed on divergence.

Registry consistency and TOCTOU

If an Osnias-ID binding can change after authorization is created but before EVM release, a time-of-check/time-of-use risk appears. Production logic should bind the authorization to a registry version, immutable release-beneficiary commitment or escrow-specific resolution state. Divergence between registry views should fail closed.

Control-plane separation

Upgrade, emergency and registry administration must not restore single-key release authority. In particular, the operational signer should not possess unilateral authority to rewrite the cold release destination or disable the second-domain requirement.

Verifier trust boundary. The cross-chain verifier is an explicit security boundary. Implementation must define canonical Sei-state authentication, the accepted finality and reorganization policy, the mechanism for verifier rotation or replacement, and the quorum or proof condition required before EVM release. Until these elements are demonstrated in code and tests, SEC-003 remains OPEN.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

WW=00: Standalone Escrow Security Mode

The same architecture can operate without clearing. WW=00 may be reserved as an explicit escrow-only mode: no clearing room, no 7/28/91-day cycle, no multilateral netting and no clearing-specific state transition. Osnias-ID then acts as the security binding between the EVM escrow, the independent authorization domain and the pre-committed release destination.

WW=00 means “no clearing cycle / escrow-only mode”. It must never be interpreted as a zero-week clearing cycle.

In this mode, the second-domain event may take the form of a release authorization, mirrored state transition, policy approval or another uniquely bound event accepted by the verifier. The single-key-insufficiency objective remains applicable.

Cryptographic Hygiene, Identity Renewal and Off-Boarding

Osnias supports voluntary full renewal of a participant’s cryptographic identity as an operational-security and cryptographic-hygiene mechanism. The protocol does not prescribe a mandatory renewal interval. The participant decides whether and when to renew according to its own security policy, governance, custody arrangements and risk assessment.

A participant may choose annual, biennial, five-year, event-driven or other renewal cycles. These are participant decisions and do not represent a protocol-defined lifetime for ECDSA or secp256k1 keys.

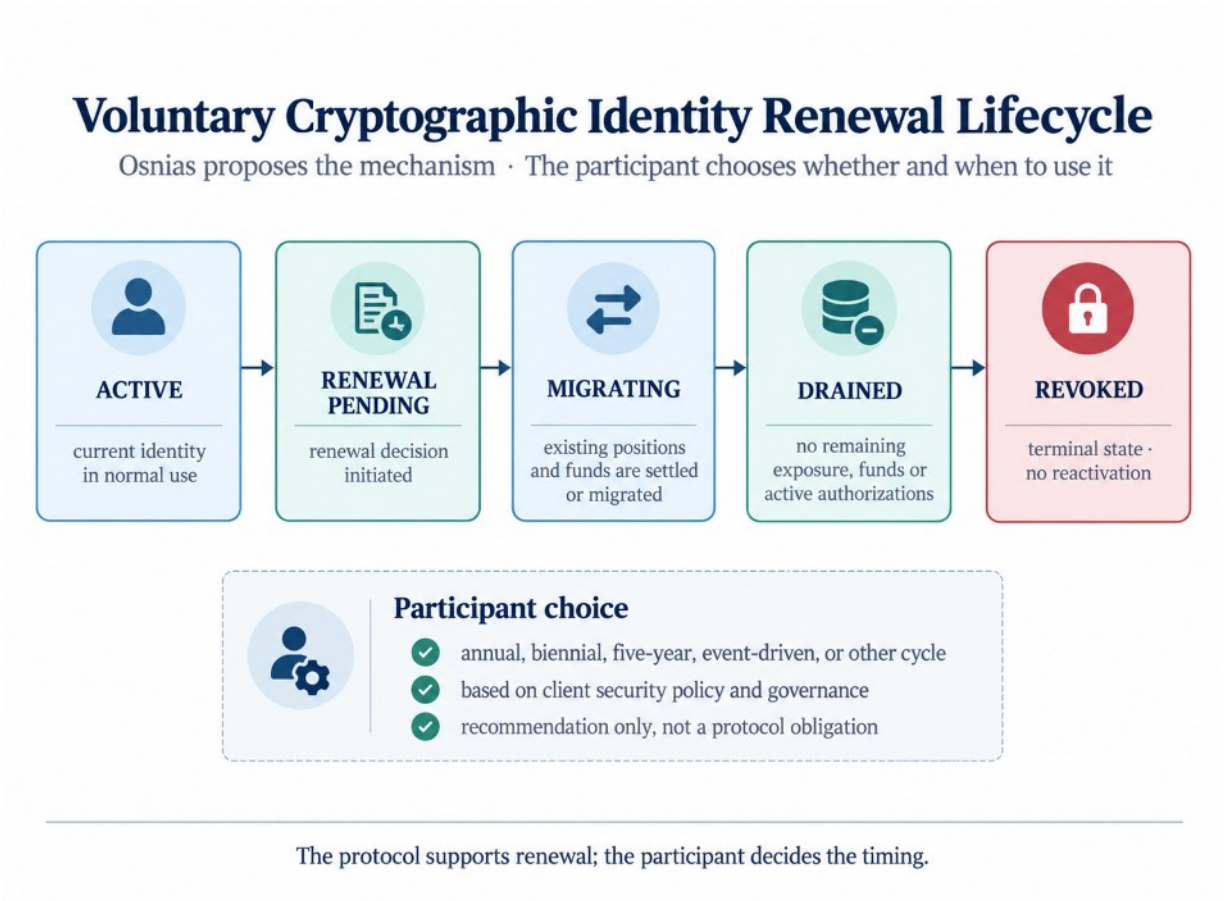


Figure 2 — Voluntary identity renewal lifecycle 10

Full renewal

A full renewal creates a genuinely new security identity rather than modifying an existing key binding in place. It may include a new Osnias-ID, a new independent EVM operational seed, a new independent Sei seed, a new independent cold release seed, new on-chain addresses, new registry bindings and controlled migration or settlement of existing positions and funds.

Migration risk boundary. Migration is treated as a heightened-risk lifecycle state. A successor binding should not become effective until migration authorization, registry version, destination commitments and remaining-

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

position state have been verified. The implementation should prevent new exposure from being associated with the historical identity once the controlled transition is complete.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

Off-boarding and terminal revocation

The previous identity remains available for historical verification and audit while losing all capacity to create new authorization events after final revocation. A possible lifecycle is ACTIVE → RENEWAL PENDING → MIGRATING → DRAINED → REVOKED. REVOKED is terminal and must not be reversible.

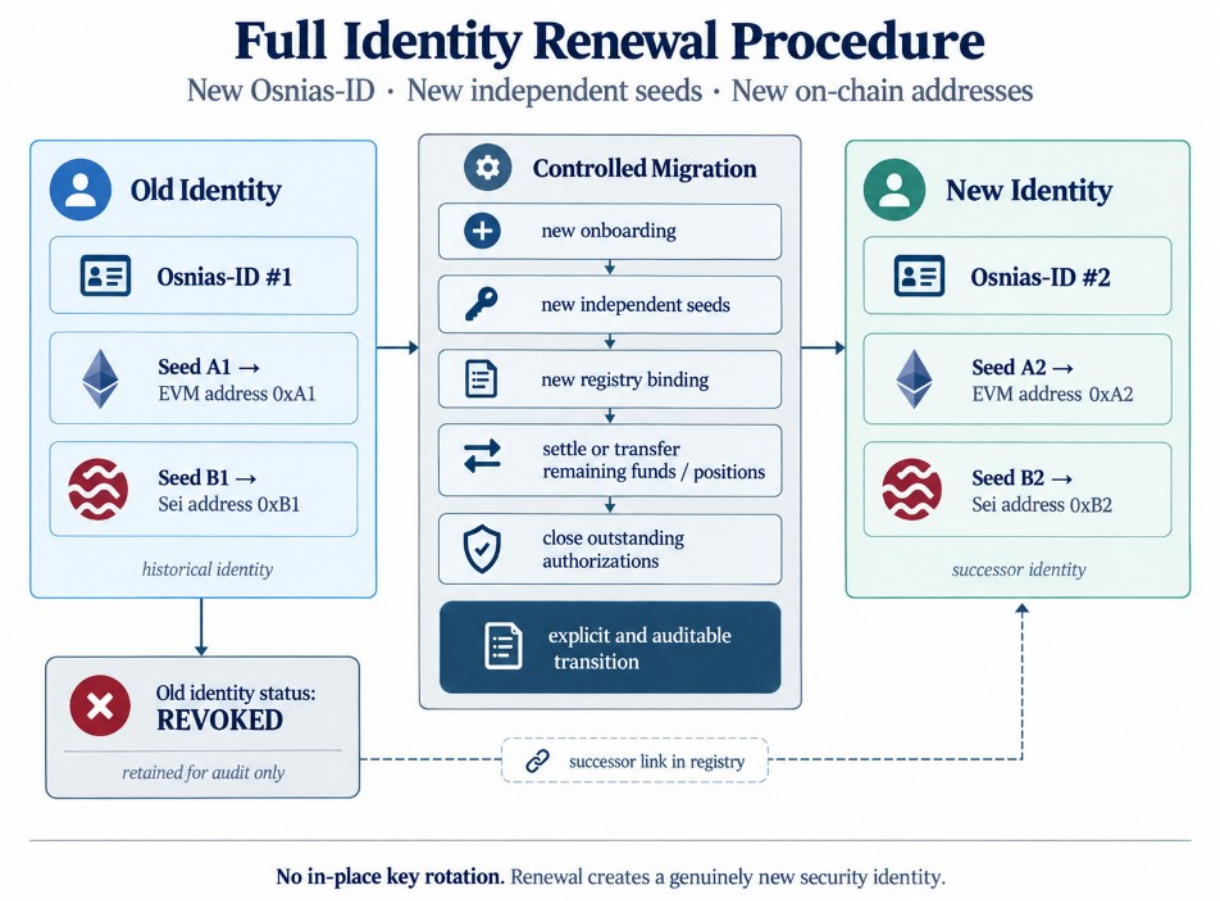


Figure 3 — Full identity renewal procedure 11

Where appropriate, the registry may retain a permanent successor reference from the revoked Osnias-ID to the new Osnias-ID without altering the historical key bindings of the previous identity.

Participant Escrow Adjustment

After settlement on Monday, day 1 of the cycle, the participant has an escrow adjustment window on Tuesday, Wednesday and Thursday, days 2, 3 and 4. During this window, the participant may add funds or request withdrawal of the releasable escrow amount, subject to security controls, outstanding settlement positions and the limit applicable to the node. This authority belongs to the participant and is distinct from the node manager's powers during Monday settlement.

Withdrawals are sent exclusively to the dedicated, pre-registered withdrawal address, which is different from the escrow address. This destination is the Domain C cold receiving address described in this Book. A withdrawal request must not allow another destination to be selected; it remains subject to the composite release predicate, verification of the releasable amount and replay protection.

On Thursday, day 4, escrow is locked when the adjustment window closes. The retained amount is then immobilized for the active phase of the cycle; participant-initiated additions and withdrawals are closed until the next authorized window. This immobilization is distinct from the end-of-cycle freeze of clearing positions. The lock must not prevent settlement operations authorized for the node manager.

Calendar reference: Book 4 — Cycles / Calendar. The sequence of Monday settlement, Tuesday-to-Thursday adjustment and locking at the close of Thursday must be represented by canonical cycle state and enforced by the contracts. The exact Thursday UTC closing time and boundary handling remain to be specified in the

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

reference calendar; no time is assumed here. The 1W testnet calendar must be explicitly aligned before this same sequence is applied to it.

Management Keys and Separation of Powers

Two management roles complement participants' three security domains A, B and C. Each manager has a dedicated key derived from an independent seed: a seed specific to the manager of each node and a separate seed for the Osnias manager. These are not two additional keys to be provided by every participant. No derivation root or recovery material may be shared with Domains A, B and C or between management roles.

Node Manager and Netting Window

The node manager's key authorizes management operations only on its assigned node. During the netting window on the first Monday of the cycle, this manager has authority to execute adjustments to members' accounts in the smart contracts in accordance with the finalized net positions of the closed cycle. This Monday is the first day of the following cycle; the adjustments concern obligations from the preceding cycle.

The manager adjusts members' accounts internally and processes the node's net balance. If the node owes a net amount to the network, the manager arranges transfer of the surplus due from the relevant escrows to the node account, followed by settlement through the prescribed flow. If the node has a net credit balance, the manager waits for receipt of the net amount receivable in the node account before finalizing the corresponding adjustments in members' contracts.

Design requirements. Contracts must restrict these operations to the relevant node, members, cycle and amounts resulting from netting. The node account and settlement destinations must be identified in the registries; the management key must not permit arbitrary beneficiary selection, changes to finalized positions or use of another node's funds. Operations must be traceable and protected against duplicate execution. The authorized window must be controlled by canonical cycle state, rather than solely by the interface clock.

Osnias Manager and Node Parameters

The Osnias manager's key is separate from node managers' keys. It authorizes administration of node parameters, including assignment of node numbers and configuration of a maximum escrow limit per node in accordance with regulatory requests applicable to that node. This role alone does not confer authority to perform members' netting in place of the node manager or to dispose of escrowed assets.

The escrow limit is a control requirement to be implemented in the contracts. Its definition must specify the asset or unit of account, the scope for aggregating node escrows and the operations that could exceed the limit. Changes must be dated, versioned and logged with the relevant decision reference. The treatment of limit reductions where funds are already escrowed remains to be specified: a reduction must neither automatically release funds nor prevent settlement of existing obligations.

Key Custody and Control Evidence

Each manager retains responsibility for its own seed, private key and recovery material. For both roles, documentation must specify authorized addresses, the relevant chain and contracts, assignment, rotation and revocation procedures, compromise response and any threshold controls. Management roles remain subject to the administrative invariant: no single key may bypass the composite condition for release of a participant's funds or unilaterally change that participant's cold beneficiary.

Netting settlement operations and releases to the cold beneficiary are two separate flows to be documented and tested. Netting transfers must be justified by finalized positions and restricted to registered settlement destinations. Describing a role and its seed does not demonstrate implementation of these restrictions. The controls above have DESIGN REQUIREMENT / IMPLEMENTATION AND TESTING PENDING status.

Institutional Hardening Requirements

The architecture only survives production if operational controls preserve the separation assumed above. For institutional deployment, the following controls form part of the security model rather than administrative afterthoughts:

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

- independent key-generation domains and auditable key ceremonies, preferably with segregated HSM/custody domains;
- separate operator roles, backup and recovery paths, with explicit common-mode failure analysis;
- threshold or multi-party control for registries, verifier administration and emergency actions;
- defined key rotation, revocation, incident response and fail-closed procedures;
- immutable or tightly governed upgrade paths, with explicit separation of duties;
- no single upgrade authority may alter the release predicate or release beneficiary unilaterally;
- continuous audit logging and monitoring of registry, oracle/verifier and escrow state;
- crypto-agility so participant keys, registries and verifier authorities can migrate to standardized PQ or hybrid signatures without changing the semantic role of Osnias-ID.

Separate HSMs or approved random-generation processes provide operational evidence of key-domain separation; they do not mathematically prove independence of the complete system. Shared administrators, recovery material, vendor control planes or backup infrastructure can still create common-mode failure.

Limitations and Open Work

This document does not claim to provide a formal proof of control composition. Before any production security claim, implementation must specify the adversary and corruption model, canonical-state verification, registry consistency, verifier quorum and upgrade powers, beneficiary changes, key rotation, emergency procedures, the permissions and settlement flows of the node manager, node parameters and limits administered by the Osnias manager, and a post-quantum migration strategy.

The result should be understood as defence in depth: it can increase adversarial work factor and attack preconditions, but it cannot transform classical ECDSA into a post-quantum signature scheme. Standardized post-quantum signatures address the primitive; Osnias addresses the composition question of whether one compromised operational key should be sufficient to exercise release authority or divert funds.

Implementation and Security Validation Roadmap

This assessment defines the intended Osnias Clearing end-user security architecture, threat model, trust boundaries, audit objectives and target security properties. It distinguishes design-level controls from evidence that must be produced by the implementation and validation process.

It does not claim that those properties have already been demonstrated by deployed production code, independently audited infrastructure or a certified operational environment.

The next stage is implementation of the described architecture on the Osnias public testnet, including the composite release predicate, registry bindings, independent authorization domains, pre-committed cold release destination, replay protection, lifecycle controls and fail-closed behaviour.

Once implemented, the deployed protocol will undergo a dedicated adversarial security campaign combining static analysis, integration testing and controlled attack scenarios against the implemented system.

Validation should include, as appropriate: static analysis of deployed contracts, including Slither; adversarial testing of the release path and beneficiary binding; replay, substitution and stale-state tests; registry and lifecycle-state consistency tests; verifier and authorization-domain failure scenarios; upgrade and control-plane abuse scenarios; fail-closed tests for inconsistent or unavailable state; tests of manager permissions, netting restrictions and per-node escrow limits; and remediation followed by retesting.

The detailed attack methodology will be defined against the implemented system rather than fixed solely from the architectural design.

Following completion of the test campaign, Osnias intends to publish a separate Security Validation and Implementation Report.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.

That report should document the implementation actually tested, including relevant contract versions, deployment references, test conditions, executed attack scenarios, static-analysis findings, observed failures, remediation actions, retest results and residual risks.

This Audit Readiness assessment and the subsequent Security Validation and Implementation Report serve different purposes: this document defines the security design, control objectives, open findings and required evidence; the future report will document how the implemented protocol behaved under static analysis, adversarial testing, remediation and retesting.

No successful implementation or security outcome is assumed in advance.

Conclusion

Assessment conclusion. The reviewed architecture defines a clear separation between the operational EVM signer, the independent Sei authorization domain and the pre-registered cold beneficiary. The main objective is precise and testable: compromise of one operational ECDSA key should not, by itself, satisfy all release conditions or redirect escrowed funds to an attacker-controlled address.

At the present document level, this remains a target security property and design objective, not an implementation finding or independently verified security result. Contract implementation, canonical-state authentication, verifier governance, administrative enforcement, adversarial testing, remediation and retesting remain necessary before the relevant controls can be treated as verified.

This document supports audit readiness and technical review. It does not constitute an independent third-party audit, formal verification, penetration-test report, certification or production-security qualification.

Designed for current chains. Security anticipates the next risk.

Bibliography

[1] P. W. Shor, “Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer,” SIAM Journal on Computing, vol. 26, no. 5, 1997.

[2] J. Proos and C. Zalka, “Shor’s discrete logarithm quantum algorithm for elliptic curves,” Quantum Information & Computation, vol. 3, no. 4, 2003. arXiv: quant-ph/0301141.

[3] M. Roetteler, M. Naehrig, K. M. Svore, and K. Lauter, “Quantum resource estimates for computing elliptic curve discrete logarithms,” ASIACRYPT 2017, LNCS 10625.

[4] D. Johnson, A. Menezes, and S. Vanstone, “The elliptic curve digital signature algorithm (ECDSA),” International Journal of Information Security, 2001.

[5] SECG, SEC 2: Recommended Elliptic Curve Domain Parameters, Version 2.0, 2010.

[6] NIST, Module-Lattice-Based Digital Signature Standard, FIPS 204, 2024.

[7] NIST, Stateless Hash-Based Digital Signature Standard, FIPS 205, 2024.

[8] NIST SP 800-90A Rev. 1 and SP 800-90B, random bit generation and entropy-source recommendations.

[9] P. Wuille, BIP-32: Hierarchical Deterministic Wallets, 2012.

[10] G. Wood, Ethereum: A Secure Decentralised Generalised Transaction Ledger (Ethereum Yellow Paper).

[11] Sei Labs, Sei technical documentation, consensus and EVM documentation.

[12] D. Bouzon, “Osnias-ID: An internal interchain identifier for multi-chain clearing,” Osnias Clearing Technical Report, Release 2.0, 2026.

[13] ISO 19011:2026, Guidelines for auditing management systems, Edition 4, May 2026.

[14] ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection — Information security management systems — Requirements.

[15] ISO/IEC 27002:2022, Information security, cybersecurity and privacy protection — Information security controls.

[16] ISO/IEC 27005:2022, Information security, cybersecurity and privacy protection — Guidance on managing information security risks.

[17] ISO/IEC 27034-1:2011, Information technology — Security techniques — Application security — Part 1: Overview and concepts (confirmed current by ISO review).

[18] NIST Special Publication 800-218, Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities, 2022.

Standards-reference notice: references [13]–[18] are methodological and security-design references. Their citation does not imply certification, conformity assessment, endorsement or independent validation of Osnias Clearing.

© 2026 Denis Bouzon — Osnias Clearing · Licensed under CC BY 4.0.